

МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РОССИЙСКОЙ
ФЕДЕРАЦИИ

«МИРЭА – Российский технологический университет»

РТУ МИРЭА

Институт кибербезопасности и цифровых технологий

Кафедра КБ-4 «Интеллектуальные системы информационной безопасности»

МЕТОДИЧЕСКИЕ МАТЕРИАЛЫ ДЛЯ ПОДГОТОВКИ К ЗАЧЁТУ

по дисциплине

**«Теория обнаружения вторжений с применением искусственного
интеллекта»**

Теория · Разбор экзаменационных вопросов · Краткое саммари для повторения

Москва 2026

Как пользоваться этой методичкой

Методичка объединяет два списка экзаменационных вопросов по дисциплине и отвечает на них «от простого к сложному», простым языком, рассчитанным на читателя без опыта в обнаружении вторжений. Многие вопросы в исходных списках повторяются или формулируют одну и ту же мысль разными словами — здесь они сведены в общие темы, чтобы не учить одно и то же по пять раз.

Документ состоит из трёх частей. Часть I — теоретический фундамент: прочитайте её первой, она даёт базовые понятия, после которых остальные вопросы воспринимаются легко и уверенно. Часть II — подробные ответы, сгруппированные по темам (основы IDS, типы систем, методы обнаружения, данные, машинное обучение, нейросети, метрики, датасеты, атаки, вызовы и будущее). Часть III — сжатое саммари на 20–30 минут чтения: его удобно перечитать вечером перед экзаменом, чтобы быстро освежить всё в памяти.

Ключевые термины при первом появлении выделены полужирным. Английские названия приведены рядом с русскими, потому что в этой области принято использовать оба варианта (например, «обнаружение аномалий» / *anomaly detection*).

Содержание

Часть I. Теоретический фундамент

1. Вторжение, угрозы и назначение IDS
2. Что обнаруживает IDS: атаки по уровням
3. Архитектура IDS и место SIEM
4. Четыре метода обнаружения
5. Ошибки IDS: ложные срабатывания и пропуски
6. Зачем здесь искусственный интеллект
7. Минимум о машинном обучении и нейросетях

Часть II. Ответы на вопросы по темам

- A. Основы IDS
- B. Типы IDS: NIDS, HIDS, WIDS, гибридные
- C. Методы обнаружения подробно
- D. Источники данных и их предобработка
- E. Машинное обучение в IDS
- F. Нейронные сети и глубокое обучение
- G. Метрики и оценка качества
- H. Датасеты для обучения IDS

I. Конкретные атаки и их обнаружение с помощью ИИ

J. Вызовы, защита моделей, этика

K. Современные тренды и будущее

Часть III. Краткое саммари для повторения

ЧАСТЬ I. ТЕОРЕТИЧЕСКИЙ ФУНДАМЕНТ

1. Вторжение, угрозы и назначение IDS

Вторжение (intrusion) — это несанкционированное проникновение или попытка проникновения в информационную систему, сеть или устройство с целью получить доступ к данным, ресурсам или функциям. Вторжение нарушает один или несколько из трёх свойств информации, которые в совокупности называют триадой CIA: конфиденциальность (Confidentiality), целостность (Integrity), доступность (Availability).

Типичные цели и виды вторжений: кража данных, модификация данных, нарушение доступности (например, DDoS), установка вредоносного ПО, неавторизованный доступ, эскалация (повышение) привилегий, создание скрытых каналов и бэкдоров, разведка и сбор информации о системе. Защита от вторжений строится из многих средств: антивирусы, межсетевые экраны (firewall), обновление ПО, многофакторная аутентификация, резервное копирование, сегментация сети, обучение сотрудников и — в центре нашего курса — системы обнаружения вторжений.

Система обнаружения вторжений (IDS, Intrusion Detection System) — это программный или программно-аппаратный комплекс, который наблюдает за сетью или хостом, выявляет подозрительную и вредоносную активность и оповещает о ней. Основная цель IDS — своевременно обнаружить атаку и минимизировать ущерб.

Чем IDS отличается от IPS. IDS только обнаруживает и сигнализирует (это «сигнализация»), а IPS (Intrusion Prevention System) ещё и автоматически блокирует атаку (это «сигнализация с замком на двери»). IDS обычно работает с копией трафика и не задерживает его; IPS стоит «в разрыв» и может отбрасывать вредные пакеты.

Основные задачи IDS: обнаружение известных атак, выявление новых и неизвестных угроз, мониторинг в реальном времени, сбор данных для расследования инцидентов и предоставление аналитику понятных оповещений.

2. Что обнаруживает IDS: атаки по уровням

Удобно делить атаки по уровню, на котором они проявляются:

- **Сетевой уровень:** сканирование портов (port scanning), DoS/DDoS (отказ в обслуживании), подмена пакетов, атаки «человек посередине» (MitM), фрагментация для обхода защиты.

- **Уровень приложений:** SQL-инъекции, межсайтовый скриптинг (XSS), обход путей (path traversal), эксплуатация уязвимостей веб-сервисов.
- **Уровень системы/хоста:** повышение привилегий, подбор паролей (brute force), запуск вредоносных процессов, изменение системных файлов, активность вредоносного ПО.

Также различают известные атаки (для них есть готовые шаблоны) и атаки «нулевого дня» (zero-day) — ранее неизвестные, для которых шаблонов ещё нет; именно их сложнее всего обнаружить.

3. Архитектура IDS и место SIEM

Типовая IDS состоит из нескольких компонентов: сенсоры (датчики), которые собирают данные (сетевые пакеты, журналы, системные вызовы); анализатор (детектор), который применяет правила или модели и принимает решение «норма / атака»; база данных событий и сигнатур, где хранятся шаблоны угроз и история событий; и консоль управления / модуль реагирования, через который аналитик видит оповещения и настраивает систему.

SIEM (Security Information and Event Management) — система централизованного сбора и корреляции событий безопасности из множества источников (IDS/IPS, firewall, серверы, приложения). IDS предоставляет в SIEM оповещения, а SIEM связывает разрозненные события в общую картину инцидента, помогает приоритизировать и хранить данные для расследований. Примеры: Splunk, IBM QRadar, ArcSight, Elastic (ELK) Stack.

4. Четыре метода обнаружения

Это «сердце» дисциплины — большая часть вопросов так или иначе про методы. Их четыре, и они дополняют друг друга.

Сигнатурный анализ (signature-based)

Сравнивает наблюдаемые данные с базой заранее известных «подписей» (сигнатур) атак — это могут быть хэши файлов (MD5, SHA-256), фрагменты кода, последовательности байтов или шаблоны сетевого трафика. Если есть совпадение — фиксируется угроза. Плюсы: высокая точность по известным угрозам, простота, быстрота, мало ложных срабатываний. Минусы: не видит новые (zero-day) и видоизменённые (полиморфные) атаки, требует постоянного обновления базы. Аналогия: узнавать преступников по фотороботам из картотеки — отлично работает для тех, кто уже в базе.

Аномальный анализ (anomaly-based)

Сначала строит модель «нормального» поведения системы/сети, а затем помечает отклонения от неё как подозрительные. Плюсы: способен обнаруживать ранее неизвестные атаки. Минусы: высокий уровень ложных срабатываний, потому что не всякое отклонение — атака. Именно здесь чаще всего применяется машинное обучение. Аналогия: не знать всех преступников в лицо, но замечать любого, кто ведёт себя необычно.

Поведенческий анализ (behavioral)

Близок к аномальному, но акцент на поведении субъектов во времени — пользователей, процессов, устройств. Изучается обычный профиль (когда человек входит, к каким ресурсам обращается), и отклонения от профиля сигнализируют об угрозе. На этом построена технология UEBA (см. часть II).

Эвристический анализ (heuristic)

Использует правила и приближённые «здоровые» признаки подозрительности (например, программа пытается шифровать много файлов подряд — вероятно, это шифровальщик), не требуя точной сигнатуры. Это промежуточное звено между жёсткими сигнатурами и обучаемыми моделями.

Гибридный подход

Комбинирует сигнатурный и аномальный (и часто ИИ) методы: сигнатуры быстро и точно ловят известное, а аномальная/поведенческая часть закрывает новое. Дополнительная проверка несколькими методами снижает число ложных срабатываний. В курсе отдельно упоминается и троичная логика (True / False / Unknown) для экспертных систем: она позволяет честно фиксировать состояние «неопределённо», когда данных недостаточно для однозначного вывода, и запрашивать дополнительные данные вместо поспешного решения.

5. Ошибки IDS: ложные срабатывания и пропуски

Ложноположительное срабатывание (false positive, FP) — система приняла нормальное событие за атаку (ложная тревога).

Ложноотрицательное срабатывание (false negative, FN) — система пропустила реальную атаку, посчитав её нормой.

Оба типа ошибок вредны, но по-разному. Много FP — аналитики тонут в ложных тревогах и перестают им доверять («усталость от оповещений»). FN опаснее по последствиям — пропущенная атака наносит реальный ущерб. Качество IDS как раз и оценивается тем, насколько мало она делает таких ошибок (см. метрики в части II). Найти баланс между чувствительностью

(ловить все атаки) и специфичностью (не тревожиться зря) — ключевая инженерная задача.

6. Зачем здесь искусственный интеллект

Трафика становится всё больше, атаки усложняются и видоизменяются, а вручную писать сигнатуры на каждую новую угрозу невозможно.

Искусственный интеллект (ИИ) и его основная рабочая часть — машинное обучение (МО) — позволяют автоматически выучивать закономерности на исторических данных, обнаруживать сложные и ранее неизвестные атаки, адаптироваться без ручного обновления правил и снижать (при правильной настройке) число ложных срабатываний.

Главное различие задаётся наличием разметки данных:

Обучение с учителем (supervised learning) — модель учится на размеченных примерах, где известно, где норма, а где атака; хорошо классифицирует известные типы атак.

Обучение без учителя (unsupervised learning) — разметки нет; модель сама находит структуру данных и помечает отклонения как аномалии; помогает против новых атак, но даёт больше ложных тревог.

Есть и промежуточные варианты: полуобучение (semi-supervised) при частичной разметке и обучение с подкреплением (reinforcement learning) для адаптивного реагирования.

7. Минимум о машинном обучении и нейросетях

Признаки (features) — измеримые характеристики события, по которым модель принимает решение: число соединений, доля ошибочных входов, объём трафика, интервал между запросами и т. п. Превращение «сырых» данных в набор признаков называется feature engineering.

Обучение модели — это подбор внутренних параметров так, чтобы предсказания совпадали с правильными ответами. Делают это методом градиентного спуска: вычисляют ошибку, считают её градиент (направление наискорейшего роста) и сдвигают параметры в противоположную сторону маленькими шагами (шаг задаётся скоростью обучения).

Нейронная сеть — модель из слоёв «нейронов», каждый из которых берёт взвешенную сумму входов и пропускает её через нелинейную функцию активации. Сети с многими слоями называют глубокими (deep learning); они способны автоматически извлекать признаки из сложных данных.

Базовые архитектуры, которые встретятся в вопросах: полносвязные сети (для табличных данных), свёрточные CNN (для данных с локальной структурой), рекуррентные RNN/LSTM (для последовательностей и временных рядов), автоэнкодеры (для поиска аномалий). Качество моделей измеряют метриками accuracy, precision, recall, F1 и AUC-ROC. Подробно всё это разобрано в части II.

ЧАСТЬ II. ОТВЕТЫ НА ВОПРОСЫ ПО ТЕМАМ

А. Основы IDS

Что такое IDS, её цель и задачи?

IDS — система, которая мониторит сеть или хост, выявляет подозрительную активность и оповещает о ней. Цель — обнаружить атаку как можно раньше и снизить ущерб. Задачи: обнаружение известных атак, выявление новых угроз и аномалий, мониторинг в реальном времени, журналирование событий для расследования и формирование понятных оповещений для аналитика.

Какие атаки может обнаружить IDS? Примеры по уровням.

На уровне сети: сканирование портов, DoS/DDoS, MitM, подмена и фрагментация пакетов. На уровне приложений: SQL-инъекции, XSS, path traversal, эксплуатация уязвимостей. На уровне системы: brute force, повышение привилегий, запуск вредоносных процессов, активность malware. Наиболее часто на практике IDS ловит DoS/DDoS, сканирование портов и попытки эксплуатации известных уязвимостей.

Основные подходы к обнаружению: сигнатурный против аномального.

Сигнатурный сравнивает события с базой известных шаблонов — точен по известному, бессилен против нового. Аномальный строит профиль нормы и ловит отклонения — видит новое, но чаще ошибается ложными тревогами. На практике их объединяют (гибридный подход).

Ложноположительные и ложноотрицательные срабатывания — почему важны?

FP — ложная тревога (норму приняли за атаку); FN — пропущенная атака. FP перегружают аналитиков и подрывают доверие к системе; FN ведут к реальному ущербу. Эффективность IDS определяется минимизацией обеих ошибок и поиском баланса между ними, поэтому одной «точности» (accuracy) для оценки недостаточно.

Компоненты архитектуры IDS.

Сенсоры (сбор данных), анализатор/детектор (применение правил или моделей), база сигнатур и событий (хранение шаблонов и истории), консоль управления и модуль реагирования. В крупных инфраструктурах IDS дополняется SIEM для централизованной корреляции.

В. Типы IDS: NIDS, HIDS, WIDS, гибридные

NIDS и HIDS — в чём разница?

NIDS (Network-based IDS) ставится в сети и анализирует трафик, проходящий через сегмент (через зеркалируемый порт коммутатора или ответвитель). HIDS (Host-based IDS) устанавливается на конкретный узел и анализирует его журналы, системные вызовы, целостность файлов, процессы. Кратко: NIDS «слушает провод», HIDS «следит за хостом изнутри».

Сравнение NIDS и HIDS

Критерий	NIDS	HIDS
Что анализирует	сетевой трафик (пакеты, потоки)	логи, системные вызовы, файлы, процессы хоста
Охват	много узлов одного сегмента сразу	только тот узел, где установлен
Сильная сторона	видит сетевые атаки, сканирование, DDoS	видит действия на хосте, изменения файлов, локальную эскалацию прав
Слабая сторона	не видит содержимое зашифрованного трафика, нагрузка на больших скоростях	нужно ставить на каждый узел, расходует его ресурсы
Когда лучше	периметр и магистрали сети	критичные серверы, конечные точки

Гибридные IDS и их преимущество.

Гибридная IDS объединяет сетевой и хостовый сбор данных (а часто и сигнатурный + аномальный методы). Преимущество — более полная видимость: то, что не заметит NIDS (например, локальная эскалация прав), увидит HIDS, и наоборот. Это повышает покрытие и снижает число пропусков.

Беспроводные IDS (WIDS).

WIDS (Wireless IDS) следят за радиоэфиром Wi-Fi: обнаруживают несанкционированные точки доступа (rogue AP), атаки деаутентификации, попытки взлома беспроводных протоколов. Применяются там, где важна безопасность Wi-Fi — в офисах, на предприятиях.

Как работает sniffing пакетов в NIDS?

Сетевой адаптер переводится в «неразборчивый» (promiscuous) режим и через зеркалируемый порт (SPAN) или ответвитель (TAP) получает копию трафика. Анализатор разбирает заголовки протоколов (Ethernet, IP, TCP/UDP, DNS, HTTP) и содержимое пакетов, ищет сигнатуры и считает признаки потоков. Инструменты захвата и анализа: Wireshark, Zeek (ранее Bro), Suricata, Snort.

Как IDS работает с зашифрованным трафиком?

Содержимое TLS/SSL IDS напрямую не видит. Варианты: расшифровка на специальном узле (TLS-инспекция/«разрыв» с доверенным сертификатом), анализ метаданных и поведения (объёмы, тайминги, размеры пакетов, параметры TLS-рукопожатия — JA3-отпечатки), а также анализ на хосте (HIDS/EDR), где данные уже расшифрованы. ИИ помогает классифицировать вредоносный зашифрованный трафик по косвенным признакам без расшифровки.

Связь IDS и SIEM.

IDS — источник оповещений, SIEM — централизованный «мозг», который собирает события из IDS, firewall, серверов, коррелирует их, приоритизирует и хранит. Без SIEM оповещения разрознены; с ним выстраивается цепочка атаки и удобнее реагировать.

С. Методы обнаружения подробно

Принцип, плюсы и минусы сигнатурного анализа.

Принцип: сравнение объекта (файла, пакета, потока) с базой сигнатур; совпадение = угроза, после чего следует действие (удаление, карантин, блокировка, оповещение). Плюсы: высокая точность по известным угрозам, мало ложных срабатываний, простота и скорость. Минусы: бессилён против zero-day и полиморфных атак, требует постоянного обновления базы, база растёт и замедляет сканирование, обходится обфускацией/шифрованием.

Аномальный анализ: как работает и какие данные использует.

Строит базовую линию (baseline) нормального поведения по историческим данным (объёмы трафика, частоты соединений, профили пользователей, метрики системы), затем измеряет расстояние текущего поведения от нормы. Используются статистика (среднее, стандартное отклонение, распределения) и машинное обучение (кластеризация, Isolation Forest, автоэнкодеры). Сложности: трудно отделить редкую, но легитимную активность от атаки; нужна актуализация baseline, иначе нормальные изменения вызывают ложные тревоги.

Поведенческий и эвристический анализ.

Поведенческий анализ изучает паттерны поведения субъектов во времени и фиксирует отклонения от индивидуального профиля (основа UEBA). Эвристический анализ применяет приближённые правила-признаки подозрительности (например, массовое шифрование файлов, обращение к защищённым областям памяти) — он ловит новое без точной сигнатуры, но даёт больше ложных тревог, чем сигнатурный. Отличие от сигнатурного:

сигнатура ищет точное совпадение с известным образцом, эвристика и поведение оценивают намерение/паттерн.

Базовые линии (baselines).

Baseline — эталон «нормы», с которым сравнивают текущее поведение. Его строят на репрезентативных исторических данных и регулярно обновляют (по расписанию или онлайн), потому что нормальное поведение со временем меняется (новые сервисы, сезонность). Устаревший baseline = рост ложных срабатываний.

Троичная логика в экспертных системах.

Кроме True и False вводится третье значение Unknown («неопределённо»). Это позволяет честно работать с неполными или противоречивыми данными: если датчик зафиксировал подозрительное поведение, но данных мало, вывод = Unknown, и система запрашивает дополнительные данные (например, результат песочницы) вместо поспешного решения. Так снижается число и ложноположительных, и ложноотрицательных решений.

D. Источники данных и их предобработка

Какие источники данных использует IDS?

Сетевой трафик (пакеты, потоки), журналы событий приложений и ОС, системные вызовы, журналы аутентификации, DNS- и проxy-логи, журналы firewall, данные EDR на конечных точках, данные о поведении пользователей. Технологии сбора: NetFlow/sFlow (агрегированные потоки), PCAP (сырой трафик), Syslog (журналы), SNMP (метрики устройств). Для потоковой обработки в реальном времени применяют Apache Kafka, Apache Flink, Spark Streaming, а для хранения и поиска — Elasticsearch/ELK.

Преимущество flow-данных (NetFlow/sFlow) перед сырым трафиком.

Flow-данные — это компактные сводки о соединениях (кто, с кем, сколько байт/пакетов, какие порты), без полного содержимого. Их меньше по объёму, их проще хранить и анализировать в масштабе, они работают и для зашифрованного трафика (метаданные видны всегда), хорошо подходят для статистических и ML-признаков. Минус — нет полезной нагрузки, поэтому глубокий сигнатурный анализ по содержимому невозможен.

Предобработка данных перед ИИ: нормализация, кодирование, снижение размерности.

Нормализация/масштабирование приводит числовые признаки к сопоставимому диапазону (например, 0–1), иначе признаки с большими

значениями «забивают» остальные. Категориальные признаки (`protocol_type`, `service`, `flag`) кодируют: `one-hot encoding` создаёт по бинарному столбцу на каждое значение (не вносит ложного порядка, но увеличивает размерность), `label encoding` заменяет категории числами (компактно, но навязывает порядок). Снижение размерности (PCA, отбор признаков, автоэнкодеры) убирает избыточные признаки, ускоряет обучение и уменьшает переобучение.

Как `one-hot encoding` влияет на производительность IDS?

Плюс: корректно представляет категории без ложного порядка, что улучшает качество для признаков вроде `service`. Минус: при большом числе уникальных значений (сотни сервисов) резко растёт размерность — больше памяти и времени на обучение, риск разреженности и переобучения. Поэтому для «широких» категорий применяют группировку редких значений, хэширование признаков или `embedding`-представления.

Что такое `embedding`-пространство?

`Embedding` — плотное векторное представление категорий или объектов в пространстве небольшой размерности, где близкие по смыслу объекты расположены рядом. Вместо громоздкого `one-hot` модель учит компактные векторы (например, для IP-адресов, сервисов, доменов), которые сохраняют смысловую близость и улучшают обобщение.

Label leakage (утечка метки).

Это когда в признаки случайно попадает информация, напрямую связанная с правильным ответом (например, признак, который существует только для атак, или идентификатор, по которому однозначно вычисляется класс). Модель показывает прекрасные метрики на тесте, но в реальности не работает, потому что «подсматривала ответ». Лечится тщательной ревизией признаков и честным разделением данных по времени/источникам.

Honeypot-системы и их данные.

Honeypot — приманка, имитирующая уязвимый сервис, чтобы привлечь атакующих и собрать данные об их действиях. Плюс: почти весь трафик к honeypot заведомо вредоносный — отличный источник размеченных примеров атак и индикаторов в реальном времени. Проблемы: данные смещены (видны лишь те, кто клюнул на приманку), продвинутые атакующие распознают honeypot и обходят его, есть риск, что honeypot используют как плацдарм.

Зачем нужен «белый» (нормальный) трафик и как его собирать?

Чтобы научить модель отличать атаку, нужно показать ей много примеров нормы. «Белый» трафик собирают в контролируемой, заведомо чистой среде (изолированный сегмент, период без инцидентов), очищают от случайных аномалий и регулярно обновляют. Если нормы мало или она нерепрезентативна, аномальные модели дают много ложных тревог.

Синтетические данные и GAN; как избежать переобучения на них.

Когда реальных примеров атак мало, данные генерируют синтетически — статистическими методами, oversampling/SMOTE или генеративно-состязательными сетями (GAN). GAN состоят из генератора (создаёт правдоподобные примеры) и дискриминатора (отличает настоящие от поддельных); обучаясь «соревнуясь», генератор учится создавать реалистичные образцы атак. Чтобы не переобучиться на синтетике: смешивать её с реальными данными, проверять модель только на реальном отложенном наборе, контролировать разнообразие сгенерированных примеров и не допускать, чтобы модель училась артефактам генератора.

Как формировать негативные примеры без явной разметки атак?

Подходы: считать нормой подавляющую массу трафика из чистого периода (обучение по одному классу — one-class), генерировать аномалии искусственно (инъекция шумов, редких комбинаций), использовать данные honeypot как заведомые атаки, применять слабую разметку по эвристикам и сигнатурам, а также самообучение, где уверенные предсказания модели становятся псевдометками.

Е. Машинное обучение в IDS

Supervised против unsupervised в контексте IDS.

Supervised требует размеченных данных (норма/атака) и хорошо классифицирует известные атаки, но плохо ловит новые и зависит от качества разметки. Unsupervised работает без меток, выявляет аномалии и потенциально новые атаки, но даёт больше ложных тревог и сложнее в интерпретации. На практике часто комбинируют: unsupervised отбирает кандидатов, supervised уточняет.

Какие алгоритмы ML чаще всего применяются?

Классические: деревья решений, случайный лес (Random Forest), градиентный бустинг (XGBoost и аналоги), метод опорных векторов (SVM), логистическая регрессия, k-ближайших соседей. Для аномалий без учителя: k-means, DBSCAN, Isolation Forest, One-Class SVM, автоэнкодеры. Они популярны из-за хорошего качества на табличных данных, скорости и зрелых реализаций (scikit-learn).

Алгоритмы поиска аномалий: K-means, DBSCAN, Isolation Forest, One-Class SVM.

Сравнение алгоритмов обнаружения аномалий

Алгоритм	Идея	Плюсы	Минусы
K-means	разбивает данные на k кластеров; далёкие от центров — аномалии	прост, быстр	нужно задать k, плохо ловит кластеры сложной формы
DBSCAN	группирует плотные области; точки вне плотных зон — аномалии	не нужно задавать число кластеров, находит формы	чувствителен к параметрам плотности, тяжёл на больших данных
Isolation Forest	аномалии «изолируются» случайными разбиениями быстрее обычных точек	быстр, хорошо масштабируется, заточен под аномалии	хуже на сложных зависимостях признаков
One-Class SVM	строит границу вокруг нормальных данных; вне границы — аномалия	силён при малой доле аномалий	чувствителен к параметрам, тяжёл на больших объёмах

Как работает SVM и one-class SVM?

SVM (метод опорных векторов) ищет разделяющую границу с максимальным зазором между классами. Для нелинейно разделимых данных применяется ядровый трюк (kernel trick): данные неявно переносятся в пространство большей размерности, где их можно разделить (популярно RBF-ядро). One-Class SVM — версия для обучения по одному классу: учится только на нормальных данных и очерчивает их область; всё, что снаружи, считается аномалией. Это удобно, когда примеров атак почти нет.

Кластеризация в задаче обнаружения аномалий, пример с k-means.

Кластеризация без учителя группирует похожие записи. В IDS k-means делит трафик на k кластеров «обычного» поведения; записи, далёкие от всех центров (большое расстояние) или попавшие в крошечные нетипичные кластеры, помечаются как аномалии. Пример: разбиваем сетевые соединения по признакам (число портов, байты, длительность) на кластеры; кластер с очень большим числом уникальных портов и нулевой полезной нагрузкой соответствует сканированию.

Ансамбли: bagging и boosting.

Ансамбль объединяет много моделей, чтобы получить более точный и устойчивый результат. Bagging (например, Random Forest) обучает модели параллельно на случайных подвыборках и усредняет ответы — снижает разброс (variance). Boosting (например, градиентный бустинг) обучает модели

последовательно, каждая исправляет ошибки предыдущей — снижает смещение (bias). В IDS ансамбли повышают точность и устойчивость к шуму; можно комбинировать и разнородные модели (CNN + RNN + классический классификатор).

Градиентный спуск.

Алгоритм обучения: вычисляем ошибку модели (функцию потерь), находим её градиент по параметрам и сдвигаем параметры в сторону уменьшения ошибки маленькими шагами (размер шага — скорость обучения, learning rate). Повторяем, пока ошибка не перестанет уменьшаться. Слишком большой шаг — расходимость, слишком маленький — медленное обучение.

Снижение размерности признаков.

Методы: отбор признаков (по важности, корреляции), PCA (главные компоненты), автоэнкодеры (сжатие в скрытое представление), embedding для категорий. Цель — убрать избыточность, ускорить обучение, снизить переобучение и упростить интерпретацию.

Г. Нейронные сети и глубокое обучение

Почему нейросети хороши для обнаружения вторжений?

Они автоматически извлекают признаки (не нужно вручную придумывать все характеристики), гибки (классификация, регрессия, поиск аномалий), хорошо работают с неструктурированными данными и большими объёмами, выявляют сложные нелинейные закономерности. Решают две основные задачи: классификацию (атака/норма, тип атаки) и обнаружение аномалий.

Полносвязные, свёрточные (CNN) и рекуррентные (RNN) сети.

Полносвязные (Fully Connected) сети — для табличных данных (журналы, метрики), каждый нейрон связан со всеми нейронами предыдущего слоя. CNN (свёрточные) применяют фильтры, выделяющие локальные паттерны; в IDS их используют для данных с пространственной структурой — «изображений» трафика, спектрограмм, последовательностей байтов, анализа бинарных файлов на вредоносный код. RNN (рекуррентные) обрабатывают последовательности, учитывая порядок и зависимость во времени — естественны для потоков сетевых событий.

Чем свёрточный слой отличается от полносвязного?

Полносвязный слой соединяет каждый вход с каждым нейроном (много параметров, нет учёта расположения). Свёрточный применяет небольшой обучаемый фильтр, скользящий по входу, и переиспользует одни и те же веса

(разделение весов) — это резко уменьшает число параметров и позволяет находить локальные признаки независимо от их позиции.

LSTM и почему они эффективны для последовательностей.

LSTM (Long Short-Term Memory) — разновидность RNN с «ячейкой памяти» и затворами (вход, забывание, выход), которые регулируют, что запоминать и что забывать. Благодаря этому LSTM улавливают долгосрочные зависимости и не страдают от затухания градиента так сильно, как обычные RNN. В IDS их применяют для анализа временных рядов и последовательностей сетевых событий (например, для выявления медленных, растянутых во времени атак и MitM-аномалий).

Двунаправленные RNN (bidirectional).

Обычная RNN читает последовательность только слева направо. Двунаправленная обрабатывает её в обе стороны и объединяет результаты, поэтому решение в каждой точке учитывает и прошлое, и будущее контекст. Это повышает качество, когда доступна вся последовательность целиком (анализ записанной сессии), но не подходит для строго онлайн-анализа, где «будущее» ещё не наступило.

Автоэнкодеры для обнаружения аномалий.

Автоэнкодер учится сжимать вход в компактное представление и восстанавливать его обратно, обучаясь только на нормальных данных. Для нормы ошибка восстановления мала; для аномалии (атаки) сеть «не умеет» её хорошо восстановить, и ошибка реконструкции велика — по превышению порога фиксируется аномалия. Процесс: обучение на чистых данных → расчёт ошибки восстановления на новых данных → порог → детекция.

GAN в IDS.

Генеративно-сопоставительные сети (GAN) состоят из генератора и дискриминатора, соревнующихся друг с другом. Применение: генерация реалистичных примеров редких атак для балансировки датасета; усиление обнаружения аномалий (дискриминатор учится отличать норму от подделок); генерация adversarial-примеров для проверки устойчивости IDS.

Графовые нейросети (GNN).

Сетевое взаимодействие естественно представляется графом: узлы — хосты/пользователи, рёбра — соединения. GNN работают прямо на графе, агрегируя информацию от соседей, и хорошо выявляют то, что видно только в структуре связей: распространение DDoS, боковое перемещение, ботнеты, аномальные связи. Данные представляют как граф с признаками на узлах и рёбрах.

Batch normalization и борьба с проблемами обучения.

Batch normalization нормализует выходы слоя по мини-батчу, стабилизируя распределения активаций; это ускоряет и стабилизирует обучение, позволяет брать больший learning rate и слегка регуляризует. Градиентный взрыв (резкий рост градиентов, особенно в RNN) лечат обрезкой градиента (gradient clipping), аккуратной инициализацией, нормализацией и архитектурами LSTM/GRU; обратная проблема — затухание градиента.

Оптимизаторы: Adam, RMSprop и др.

Это улучшенные версии градиентного спуска с адаптивным шагом для каждого параметра. RMSprop масштабирует шаг по скользящему среднему квадратов градиентов. Adam добавляет ещё и momentum (инерцию) — обычно сходится быстро и устойчиво, поэтому это выбор по умолчанию для большинства IDS-моделей. SGD с momentum иногда даёт лучшее итоговое качество при тщательной настройке.

Борьба с переобучением при малом объёме данных.

Переобучение (overfitting) — когда модель «зазубрила» обучающие данные и плохо обобщает. Средства: регуляризация (L1/L2, dropout), упрощение модели, ранняя остановка (early stopping), кросс-валидация, аугментация и синтетические данные, перенос обучения (transfer learning), batch normalization. При дисбалансе — взвешивание классов и oversampling.

Интерпретируемость нейросетей: SHAP, LIME.

Нейросети — «чёрные ящики». Для объяснения их решений применяют методы объяснимого ИИ (XAI): LIME строит простую локальную модель вокруг конкретного предсказания и показывает вклад признаков; SHAP опирается на теорию игр (значения Шепли) и честно распределяет вклад каждого признака. В безопасности интерпретируемость критична: аналитик должен понимать, почему сработала тревога, чтобы доверять системе и принимать решения.

Анализ временных рядов: ARIMA и LSTM.

Многие сигналы безопасности — это временные ряды (трафик по времени, число запросов). ARIMA — классическая статистическая модель прогнозирования ряда; отклонение факта от прогноза = аномалия. LSTM — нейросетевой аналог, улавливающий сложные нелинейные и долгосрочные зависимости. ARIMA проще и интерпретируемее, LSTM мощнее на сложных паттернах.

G. Метрики и оценка качества

Accuracy, precision, recall, F1.

Считаются по матрице ошибок (TP — верно пойманные атаки, TN — верно опознанная норма, FP — ложные тревоги, FN — пропущенные атаки). Accuracy = доля всех правильных ответов — обманчива при дисбалансе. Precision (точность) = $TP/(TP+FP)$ — какая доля тревог настоящие. Recall (полнота) = $TP/(TP+FN)$ — какую долю атак мы поймали. F1 — гармоническое среднее precision и recall, баланс между ними. В IDS обычно важнее recall (не пропустить атаку) при приемлемом precision.

ROC-кривая и AUC.

ROC-кривая показывает зависимость доли пойманных атак (TPR = recall) от доли ложных тревог (FPR) при разных порогах. AUC — площадь под кривой: 1,0 — идеал, 0,5 — как случайное угадывание. AUC удобна для сравнения моделей независимо от выбранного порога и устойчивее к дисбалансу, чем accuracy.

Влияние порога; баланс чувствительности и специфичности.

Модель выдаёт оценку вероятности атаки; порог решает, с какого значения бить тревогу. Низкий порог — ловим больше атак (высокая чувствительность/recall), но больше ложных тревог; высокий — меньше ложных тревог (высокая специфичность), но больше пропусков. Порог выбирают по цене ошибок: где пропуск критичен — снижают порог; где дороги ложные тревоги — повышают. Помогают ROC- и precision-recall-кривые.

Как минимизировать ложные срабатывания?

Гибридный подход и многоступенчатая проверка, качественные и актуальные baseline, тонкая настройка порогов, обогащение контекстом (Threat Intelligence, репутация IP), корреляция событий в SIEM, борьба с переобучением, дообучение на разобранных ложных тревогах и обратная связь от аналитиков. ИИ снижает FP, выучивая более точную границу нормы и учитывая контекст.

Какие факторы снижают производительность IDS?

Большой объём и высокая скорость трафика, сложные и многочисленные правила, ограничения оборудования (CPU/память), доля зашифрованного трафика, плохое качество и устаревание данных/baseline, неоптимальная модель. Решения: flow-данные вместо сырого трафика, распределённая/масштабируемая архитектура, аппаратное ускорение, оптимизация моделей.

Н. Датасеты для обучения IDS

Сравнение KDD Cup 1999, NSL-KDD, CIC-IDS2017, UNSW-NB15.

Популярные датасеты для IDS

Датасет	Год	Особенности
KDD Cup 1999	1999	классика; много дубликатов и избыточности, устарел, завышает метрики
NSL-KDD	2009	очищенная версия KDD99 без дубликатов; компактен, удобен для учёбы; всё ещё устаревший набор атак
CIC-IDS2017	2017	современный, реалистичный трафик, разнообразные атаки (DoS, brute force, веб, ботнет), большой объём (PCAP)
UNSW-NB15	2015	современные типы атак, богатый набор признаков, хорош для сравнения моделей

Риски устаревших и нерепрезентативных датасетов.

Модель, обученная на старых данных (как KDD99), не знает современных атак и техник, переоценивает своё качество из-за дубликатов и не работает в реальной сети. Поэтому берут актуальные наборы (CIC-IDS2017, UNSW-NB15), дополняют собственными данными организации и регулярно обновляют обучающую выборку.

Дисбаланс классов в датасетах.

Атаки (особенно редкие категории, как U2R в NSL-KDD) встречаются намного реже нормы. Модель склоняется к преобладающему классу и плохо ловит редкие атаки, а высокая ассурасу создаёт иллюзию качества. Лечится взвешиванием классов, oversampling/SMOTE, undersampling, генерацией синтетики (GAN) и оценкой по precision/recall/F1, а не по ассурасу.

I. Конкретные атаки и их обнаружение с помощью ИИ

DDoS.

Признаки: резкий рост запросов/трафика к одному ресурсу со множества IP. ИИ выявляет аномальные всплески по потоковым признакам (число соединений, пакетов в секунду, энтропия IP-адресов); хорошо подходят потоковые модели и GNN, анализирующие структуру источников.

Сканирование портов и brute force.

Сканирование: один источник обращается ко многим портам одного хоста, много отказов, короткий интервал. Brute force: множество неудачных попыток входа к одному сервису/учётке. Признаки (число уникальных портов, доля отказов, число неудачных логинов в окне) легко формализуются и хорошо классифицируются ML.

SQL-инъекции и XSS.

SQLi проявляется спецсимволами и SQL-конструкциями в параметрах (' OR '1'='1, UNION SELECT, DROP TABLE); XSS — внедрением HTML/JS (<script>, onerror=, javascript:). CNN/RNN анализируют последовательности символов веб-запросов и выявляют вредоносные паттерны точнее жёстких регулярных выражений; помогает обработка текста запросов (NLP-подходы).

MitM и replay-атаки.

MitM (человек посередине) перехватывает/подменяет трафик — выдаёт себя аномалиями в таймингах, маршрутах, параметрах TLS; LSTM на последовательностях событий ловит такие отклонения. Replay-атака повторно отправляет ранее перехваченные легитимные сообщения; нейросети выявляют дубли и нарушения временных/счётчиковых паттернов, нехарактерные для нормального обмена.

APT (продвинутые устойчивые угрозы).

APT — длительные, скрытные, многоэтапные атаки. Их трудно поймать одним событием; нужны корреляция во времени и по разным источникам, поведенческая аналитика и deep learning, связывающие слабые сигналы (разведка → закрепление → боковое перемещение → эксфильтрация) в единую цепочку.

Атаки нулевого дня (zero-day) и supply chain.

Zero-day неизвестны заранее, поэтому сигнатуры бессильны — спасают аномальные и поведенческие методы, выявляющие отклонение от нормы. Атака на цепочку поставок (supply chain) компрометирует доверенного поставщика/обновление ПО, чтобы проникнуть к его клиентам; обнаруживается контролем целостности, поведенческим анализом обновлений и аномалиями в поведении доверенных компонентов.

Внутренние угрозы (insider threats) и анализ бинарных файлов.

Инсайдер действует с легальными правами, поэтому ключ — поведенческая аналитика (UEBA): отклонение от индивидуального профиля (необычные объёмы доступа, время, ресурсы). Для вредоносного кода глубокие свёрточные сети анализируют байты/образы бинарных файлов и выявляют вредоносные паттерны без запуска.

Безопасность IoT.

IoT-устройства многочисленны, маломощны и однообразны по поведению, что упрощает построение профиля нормы. Подходят лёгкие

модели, автоэнкодеры и LSTM на телеметрии; часто детектирование выносят на шлюз/край сети (edge) из-за ограниченных ресурсов устройств.

J. Вызовы, защита моделей и этика

Ключевые проблемы ИИ в IDS.

Качество и нехватка размеченных данных, дисбаланс классов, устаревание данных, переобучение, слабая интерпретируемость («чёрный ящик»), высокая ресурсоёмкость, уязвимость самих моделей к атакам и адаптивность атакующих (маскировка, многоэтапность).

Adversarial-атаки и защита.

Adversarial-атака вносит малые, незаметные человеку изменения во вход, чтобы обмануть модель (перевести атаку в класс «норма»). Отравление данных (data poisoning) портит обучающую выборку. Защита: adversarial training (дообучение на состязательных примерах), robust training и регуляризация, контроль и валидация обучающих данных, ансамбли и обнаружение аномальных входов, ограничение и мониторинг доступа к модели.

Интерпретируемость и доверие.

Без объяснений аналитики не доверяют системе и не могут проверить решения. Применяют XAI (SHAP, LIME), визуализацию признаков и анализ важности, а также гибридные модели, где часть логики прозрачна. Это особенно важно для расследований и юридической обоснованности.

Этические и правовые аспекты.

Сбор и анализ данных затрагивают приватность и профилирование пользователей; нужно соблюдать GDPR и иные регуляторные требования (минимизация и обезличивание данных, законные основания обработки, хранение). Возникают вопросы ответственности за ошибки модели (пропущенная атака) и риск злоупотребления технологиями. При использовании сторонних облачных сервисов важно минимизировать риск утечки передаваемых данных.

Ресурсы и масштабируемость.

Обучение и инференс ИИ-моделей требуют значительных вычислительных ресурсов. Масштабируемость обеспечивают распределённой обработкой (Kafka/Spark/Flink), горизонтальным масштабированием, оптимизацией и сжатием моделей, выносом части вычислений на край сети и использованием GPU/ускорителей.

К. Современные тренды и будущее

UEBA и DLP.

UEBA (User and Entity Behavior Analytics) — поведенческая аналитика пользователей и сущностей: строит профили нормального поведения и выявляет отклонения (инсайдеры, скомпрометированные учётки). DLP (Data Loss Prevention) предотвращает утечки данных; ИИ классифицирует чувствительный контент и обнаруживает аномальные передачи (эксфильтрацию).

Обучение с подкреплением и автоматизация реагирования.

Reinforcement learning: агент учится выбирать действия (блокировать, изолировать, эскалировать), получая «награду» за правильные решения. Применяется для адаптивного реагирования и автоматизации SOC — приоритизации оповещений и автоматических ответов на инциденты.

Федеративное и онлайн-обучение.

Федеративное обучение (federated learning) обучает общую модель на данных многих организаций/устройств без передачи самих данных в одно место — улучшает качество и сохраняет приватность; ограничения — сложность согласования и риск отравления со стороны участников. Онлайн-обучение обновляет модель на потоке новых данных без полного переобучения — модель быстро адаптируется к новым угрозам, но рискует «забыть» старое и подвержена отравлению.

Самообучающиеся системы и объяснимый ИИ.

Будущее — самонастраивающиеся IDS, которые автоматически адаптируются к новым угрозам, и объяснимый ИИ (XAI), повышающий доверие. Развиваются гибридные архитектуры (сигнатуры + ИИ), коллаборативная защита (обмен индикаторами между системами) и потенциально квантовые вычисления для сверхбыстрой обработки и оптимизации.

Облако, IoT, DevSecOps.

В облаке IDS адаптируется к динамичной инфраструктуре и использует встроенные сервисы (AWS GuardDuty, Azure Defender/Security Center, Google Security Command Center). В IoT — лёгкие модели и анализ на краю сети. В DevSecOps безопасность встраивается в конвейер разработки: автоматические проверки, мониторинг и обнаружение аномалий на всех этапах CI/CD.

Инструменты и фреймворки.

Сбор и анализ трафика: Wireshark, Zeek, Suricata, Snort. SIEM и аналитика: Splunk, IBM QRadar, Elastic (ELK) Stack, Darktrace. Мониторинг и визуализация: Prometheus, Grafana. Поточковая обработка: Apache Kafka, Flink, Spark Streaming. Разработка моделей: scikit-learn, TensorFlow/Keras, PyTorch.

Примеры применения и компании.

ИИ в IDS активно используют облачные провайдеры (AWS, Microsoft Azure, Google Cloud) и специализированные вендоры (Darktrace с поведенческой аналитикой, Cisco, IBM, Splunk). Типовые успешные сценарии: обнаружение DDoS по аномалиям трафика, выявление инсайдеров через UEBA, классификация вредоносного ПО, анализ зашифрованного трафика по метаданным.

ЧАСТЬ III. КРАТКОЕ САММАРИ ДЛЯ ПОВТОРЕНИЯ

Этот раздел рассчитан на 20–30 минут чтения — перечитайте его перед экзаменом, чтобы быстро освежить все темы. Каждый пункт — сжатая суть.

1. База.

Вторжение нарушает конфиденциальность, целостность или доступность (триада CIA). IDS обнаруживает и оповещает; IPS ещё и блокирует. Компоненты IDS: сенсоры, анализатор, база сигнатур/событий, консоль/реагирование. SIEM централизованно собирает и коррелирует события (Splunk, QRadar, ELK).

2. Типы IDS.

NIDS слушает сетевой трафик (видит сетевые атаки, не видит содержимое зашифрованного и локальные действия); HIDS следит за хостом (логи, файлы, процессы). WIDS — для Wi-Fi. Гибридные объединяют оба и дают максимальное покрытие. Сниффинг — захват копии трафика в promiscuous-режиме (Wireshark, Zeek, Suricata).

3. Методы обнаружения.

Сигнатурный — точно ловит известное, бессилен против zero-day, нужна база. Аномальный — строит baseline нормы и ловит отклонения, видит новое, но много FP. Поведенческий — отклонения от профиля субъекта (UEBA). Эвристический — приближённые правила. Гибридный — комбинация, меньше ошибок. Троичная логика добавляет состояние Unknown для неполных данных.

4. Ошибки и метрики.

FP — ложная тревога, FN — пропуск атаки. Матрица ошибок: TP/TN/FP/FN. $\text{Precision} = \text{TP}/(\text{TP} + \text{FP})$, $\text{Recall} = \text{TP}/(\text{TP} + \text{FN})$, F1 — их баланс. Accuracy обманчива при дисбалансе. ROC показывает TPR vs FPR, AUC — площадь под ней (1 — идеал, 0,5 — случай). Порог регулирует баланс чувствительности и специфичности.

5. Данные и предобработка.

Источники: трафик, логи, системные вызовы, NetFlow, PCAP, Syslog, SNMP. Flow-данные компактны, работают с шифрованием, но без содержимого. Предобработка: нормализация, кодирование категорий (one-hot — без ложного порядка, но раздувает размерность; label — компактно, но навязывает порядок), снижение размерности (PCA, автоэнкодеры), embedding. Остерегаться label leakage. Нужны репрезентативный «белый»

трафик и баланс классов; редкие атаки добирают oversampling/SMOTE/GAN; honeypot даёт заведомо вредоносные примеры.

6. Машинное обучение.

Supervised (размечено, ловит известное) против unsupervised (без меток, ловит новое). Классика: деревья, Random Forest, бустинг, SVM (kernel trick для нелинейности). Аномалии: k-means, DBSCAN, Isolation Forest, One-Class SVM, автоэнкодеры. Ансамбли: bagging ($\downarrow$ variance, RF) и boosting ($\downarrow$ bias). Обучение — градиентный спуск с learning rate.

7. Нейросети.

Полносвязные — табличные данные; CNN — локальные паттерны, анализ бинарников/«изображений» трафика; RNN/LSTM — последовательности и временные ряды (LSTM держит долгую память затворами); BiRNN читает в обе стороны; автоэнкодеры — аномалии по ошибке восстановления; GAN — генерация примеров и проверка устойчивости; GNN — анализ графа связей (DDoS, боковое перемещение, ботнеты). Оптимизаторы Adam/RMSprop, batch normalization стабилизирует обучение, градиентный взрыв лечат clipping. Переобучение — dropout, регуляризация, early stopping. Интерпретация — SHAP, LIME (XAI).

8. Датасеты.

KDD99 (устарел, дубликаты) → NSL-KDD (очищен, для учёбы) → CIC-IDS2017 и UNSW-NB15 (современные, реалистичные). Главная беда — дисбаланс классов и устаревание; оценивать по precision/recall/F1/AUC, а не accuracy.

9. Атаки и их обнаружение.

DDoS — аномальные всплески, GNN; сканирование/brute force — счётчики портов/неудачных входов; SQLi/XSS — паттерны в веб-запросах, CNN/RNN; MitM/replay — аномалии таймингов и повторы, LSTM; APT — корреляция слабых сигналов во времени; zero-day — аномальные методы; supply chain — целостность и поведение обновлений; insider — UEBA; IoT — лёгкие модели на краю; вредоносные бинарники — CNN по байтам.

10. Вызовы и будущее.

Проблемы: качество/дисбаланс/устаревание данных, переобучение, интерпретируемость, ресурсы, adversarial-атаки и отравление данных. Защита моделей — adversarial/robust training, контроль данных. Этика — приватность, GDPR, ответственность. Тренды: UEBA, DLP, reinforcement learning, федеративное и онлайн-обучение, самообучающиеся и объяснимые

системы, облачные IDS (GuardDuty, Azure, GCP), IoT/edge, DevSecOps, потенциал квантовых вычислений.

Если вы уверенно пересказываете эти десять блоков своими словами и можете привести по паре примеров к каждому — вы готовы к зачёту. Удачи!